

Plan 2 — Data Retention & Deletion

Status: Locked 2026-04-24 **Companion docs:** [plan-1-auth.md](#), [plan-3-integration-scope.md](#), [plan-4-integration-tech.md](#), [plan-5-llm-cost.md](#), [Skillnex_Privacy_Compliance_Engineering_Guide.pdf](#)

Executive summary

Skillnex automates retention enforcement for fourteen data categories — from short-lived sessions to long-lived audit logs. Deletion runs every six hours via cron, no human in the loop. Customers can purge their account at will (with a 90-day grace) or trigger right-to-deletion for individual employees within a 7-day SLA (faster than the 30-day GDPR ceiling). Special-category data (race, religion, health, etc.) is hard-rejected at parse time. Anthropic's default 30-day API retention is disclosed in the DPA during the pilot; Zero Data Retention is requested post-pilot. Backups persist customer data up to 30 days after deletion — disclosed in the DPA, the same standard AWS, Stripe, and Microsoft offer.

Locked decisions

#	Decision
1	Default tenant retention: 90 days post-cancellation (EU automatically capped at 30)
2	Right-to-deletion SLA: 7 days in DPA , automated to <24 hrs
3	Anthropic ZDR: request post-pilot ; DPA discloses default 30-day retention during pilot
4	Tokenization (replace names with employee_key in LLM prompts): Month 3 , not MVP
5	Backup retention: 30 days (DO snapshot rotation, industry standard)
6	Special-category columns: hard reject at parse
7	PDF exports: stream-only, no persistence
8	LLM call logs (our side): metadata only — no full prompt logging
9	EU data residency: disclosed in DPA, US infrastructure during pilot ; real EU region when 2nd EU customer signs

Data inventory — every category we hold

#	Category	Storage	Contains PII?	Sensitivity
1	Tenant record	tenants row	Company name only	Low
2	User accounts	users row	Email, name, password hash	Medium
3	Sessions	sessions row	IP, UA, user link	Medium (auto-expires)
4	Invitations	invitations row	Invitee email	Low (auto-expires)
5	Employees	employees row	Name, salary, role, dept, signals	High — primary PII
6	Per-employee narratives	employees.narrative JSON	LLM output citing employee	High
7	Competencies + manager comment + self-assessment (Phase 2)	competencies table	Manager prose, employee prose	High
8	Verified signals from integrations (Plan 3)	integration_signals table	Per-employee activity	High
9	Audit log	audit_log row	Who did what when	Metadata, sensitive but not PII
10	Uploaded raw xlsx files	DO volume / S3	Full original workbook	High
11	LLM API call traces	server logs	Could echo employee data if logged carelessly	High if logged carelessly
12	Anthropic side cache	Out of our control	Whatever we sent in a prompt	Per Anthropic retention contract
13	Backups	DO snapshot store	Everything as of snapshot time	High
14	PDF exports of reviews	Stream-only, never persisted	Per-employee review	High

Retention defaults — per category

These are the defaults baked into code. Tenants can pick a shorter window in their settings; longer requires explicit DPA amendment.

Category	Default retention	Trigger for deletion	Notes
Tenant record	Lifetime + 30 days post-cancellation	Owner cancels OR right-to-deletion	After 30 days, hard-deleted

Category	Default retention	Trigger for deletion	Notes
User accounts (active tenant)	Lifetime of tenant	Admin removes user → soft-delete 30 days → hard delete	Right-to-deletion bypasses grace
Sessions	30 days	Auto-expire	Deleted nightly via cron
Invitations	7 days	Auto-expire or accepted	Deleted nightly
Employees + narratives + competencies + signals	90 days post-tenant-cancellation OR 30 days post-individual-deletion	Whichever first	Load-bearing PII. EU tenants automatically capped at 30 days
Audit log	Lifetime of tenant + 1 year	Hard delete after 1 year	Legal-defense window
Uploaded raw xlsx	30 days from upload	Auto-delete	Parsed data persists in employees; raw is for support only
LLM API call traces	7 days	Cron sweep	Truncate prompts to first 50 chars; never log full employee JSON
Backups	30 days	DO snapshot rotation	Disclosed in DPA
PDF exports	Stream-only	n/a	Generate, send, delete temp file
Anthropic API side	30 days during pilot; ZDR post-pilot	Contract toggle	Disclosed in DPA either way

Deletion triggers — four legal paths

A. Tenant cancellation (Owner clicks "Delete account")

- `tenants.deleted_at = now()`
- All users immediately suspended (sessions revoked)
- Audit log records the cancellation
- Email to Owner: *"Your data will be permanently deleted in 90 days. To restore, contact us within that window. To delete immediately, click [Delete Now Permanently]."*
- Cron at T+90 days: hard-delete every row WHERE `tenant_id = X`
- Audit log keeps a metadata-only entry: `"tenant_id X hard-deleted, N rows removed at Y"`

B. Right-to-deletion request (single employee)

GDPR/CCPA legal right. Two arrival paths:

- **Self-serve:** Employee role user → `/app/my-review` → "Delete my data" → confirms
- **Manual:** external email (someone whose data we hold but who doesn't have a Skillnex account); HR processes via `/app/settings/data` admin view

Process:

- Request stored with timestamp
- Within 7 days (DPA SLA, automated to <24 hrs in practice): hard-delete every row for that `employee_key` across `employees`, `competencies`, `signals`, `narratives`
- Linked user account hard-deleted (no soft-delete grace)
- Audit log records deletion with metadata only — no PII in the log
- Backups: DPA discloses that data may persist in encrypted backups for up to 30 days; after the next 30-day rotation cycle, no backup contains the data
- Email confirmation to requester

C. Tenant retention policy expiry (per-tenant settings)

A tenant might set "auto-delete employee data 60 days after upload" if their internal policy demands it. Cron checks `employees.uploaded_at` against `tenants.retention_days` nightly and hard-deletes anything older. EU tenants are capped at 30 days regardless.

D. User suspended/removed by Admin

- Soft-delete on `users` row, sessions revoked
- 30-day grace: Admin can restore via `/app/settings/team`
- After 30 days: hard-delete `users` row only — performance data persists separately keyed by `employee_key`

Automated retention sweep

```
``ts // lib/retention/sweep.ts async function runRetentionSweep() { // 1.
Hard-delete tenants past their grace window // 2. Hard-delete employees past
tenant's retention_days // 3. Hard-delete users soft-deleted >30 days ago // 4.
Expire sessions past expires_at // 5. Expire invitations past expires_at // 6.
Truncate LLM call logs older than 7 days // 7. Process pending right-to-deletion
requests; SLA breach → page on-call // 8. Hard-delete audit_log entries older
than tenant_lifetime + 1 year // 9. Log a summary event to audit_log } ``
```

Each branch is independent. Failures don't cascade. Every action audit-logged.

Schedule: every 6 hours via `node-cron` in-process. Same scheduler that runs integration pulls (Plan 4).

User-facing affordances

Three pages required for legal compliance.

`/app/settings/data` (Owner + Admin)

Section	Content
What we hold	Counts: 110 employees, 100 narratives, 5,200 audit-log entries, last upload 2 days ago. Inspired by Microsoft Compliance Center.

Section	Content
Export	Two streamed buttons: "Export all employee data (JSON)", "Export audit log (CSV)"
Retention setting	Slider/select: 30 / 60 / 90 days. EU tenants capped at 30.
Right-to-deletion	Form: paste employee_key or email, submit, deletion logged + scheduled
Delete account	Big red button, confirms via email, triggers tenant cancellation flow

/app/my-review (Employee)

Section	Content
My data	Plain-English summary: review, scores, signals
Download my review	PDF export of own data (stream-only)
Delete my data	Self-serve right-to-deletion

/app/settings/audit-log (Owner + Admin)

Filterable list of all audit events: timestamp, user, action, target. Export to CSV.

Anthropic — out of our DB but in our DPA

Default Anthropic retention: 30 days for API request logs (abuse detection).

Pilot path: disclose default 30-day retention in DPA. Customer accepts as condition of pilot.

Post-pilot path: request Zero Data Retention from Anthropic (free email to their sales team, granted to most enterprise customers). Once granted, prompts and outputs are not logged at all.

Tokenization (Month 3): replace employee names with `Employee_S001` in prompts before sending to Anthropic; map back locally for narrative display. Slight prose-quality cost; large privacy gain. Deferred per Subject 2 decision.

Backups — the standard tradeoff

DigitalOcean volume snapshots are managed by DO. Daily snapshot, 30-day retention. After deletion, customer data persists in old snapshots until rotation (~30 days).

DPA wording (locked):

"Customer data may persist in encrypted backups for up to 30 days after deletion. Backups are encrypted at rest and access is restricted to designated engineers under documented incident-recovery procedures."

This is the same posture AWS, Stripe, and Microsoft offer. Acceptable in every enterprise contract.

Special-category data — explicit refusal

GDPR Article 9 categories (prohibited unless explicit consent):

- Health (disability, sick leave, accommodations, FMLA)
- Race, ethnicity
- Religion
- Sexual orientation
- Political opinions
- Trade union membership
- Biometric data

Skillnex does not ingest any of these in MVP. The xlsx parser hard-rejects columns matching keywords:

```
``ts const SPECIAL_CATEGORY_KEYWORDS = [ "race", "ethnicity", "religion", "sexual",  
"political", "union", "biometric", "disability", "medical", "health", "fmla",  
"ada_accommod", "pregnancy", "marital", ]; ``
```

Parse error: *"Skillnex does not process special-category data per GDPR Art. 9. Remove these columns and re-upload."*

Same enforcement applied at integration level (Plan 3): HRIS adapter never pulls these fields even if granted scope.

DPA — what gets disclosed

This plan generates ~80% of the DPA's content:

- **Data we process** — categories from §Data inventory above
- **Lawful basis** — performance of contract (GDPR Art. 6(1)(b)) + legitimate interest (Art. 6(1)(f))
- **Retention periods** — table from §Retention defaults
- **Deletion guarantees** — 7 days individual, 90 days post-cancellation, 30 days backup window
- **Sub-processors** — Anthropic, DigitalOcean, Resend (auto-generated from Plan 3 config)
- **Breach notification** — 72 hours per GDPR
- **International transfers** — EU SCCs included for any EU customer data flowing to US infrastructure
- **Special-category data** — refused; Skillnex is not a HIPAA Business Associate
- **Customer responsibilities** — accuracy of uploaded data, lawful basis for processing their employees

Cost: \$500-\$1,500 for legal template review per privacy guide. Required before law firm pilot signs.

Build sequence (1.5 days on top of Plan 1)

Day	Work
Day 1 (with Plan 1 schema)	Add <code>retention_days</code> , <code>deleted_at</code> to <code>tenants</code> . Add <code>right_to_deletion_requests</code> table.

Day	Work
Day 2 (with auth)	Hook audit-log writes into login/logout/role-change/data-access
Day 4 (with <code>/settings/data</code>)	Build export buttons (JSON + CSV streamers). Right-to-deletion form. "What we hold" summary panel.
Day 5 (Plan 2 specific)	<code>runRetentionSweep()</code> cron + Vitest tests for each branch. Wire to 6-hour interval.
Day 6	Special-category column blocker added to <code>lib/parsers/schema.ts</code> . Parse error tested.
Day 7	Email Anthropic to request ZDR (post-pilot). DPA template drafted (or hire \$500-1,500 lawyer review).

Tests that prove it works

Test	Verifies
<code>tests/retention/sweep.test.ts</code> — tenant 91 days past cancellation → all rows deleted	Tenant cancellation path
<code>tests/retention/sweep.test.ts</code> — employee 7 days after right-to-delete request → all rows deleted	Individual deletion
<code>tests/retention/sweep.test.ts</code> — employee uploaded 91 days ago, tenant retention=90 → deleted	Tenant retention setting
<code>tests/retention/sweep.test.ts</code> — session past <code>expires_at</code> → deleted	Session cleanup
<code>tests/retention/sweep.test.ts</code> — EU tenant <code>retention_days</code> defaults to 30, ignored if user sets 90	EU cap enforcement
<code>tests/parsers/schema.test.ts</code> — column "race" → parse rejected with specific error	Special-category blocker
<code>tests/parsers/schema.test.ts</code> — column "medical_history" → rejected	Special-category blocker
<code>tests/parsers/schema.test.ts</code> — column "performance_score" → accepted	False-positive guard
<code>tests/audit-log.test.ts</code> — every login, every right-to-deletion, every export produces an entry	Audit completeness
<code>tests/audit-log.test.ts</code> — UPDATE on <code>audit_log</code> throws	Append-only enforcement

Items deferred

- Tokenization layer for LLM prompts — Month 3

- Anthropic Zero Data Retention — request post-pilot
- Real EU data residency (separate region) — when 2nd EU customer signs
- Customer-managed encryption keys (AWS KMS) — Year 1
- Penetration test — Month 6
- SOC 2 Type II audit — Month 12-18
- ISO 27001 — Year 2